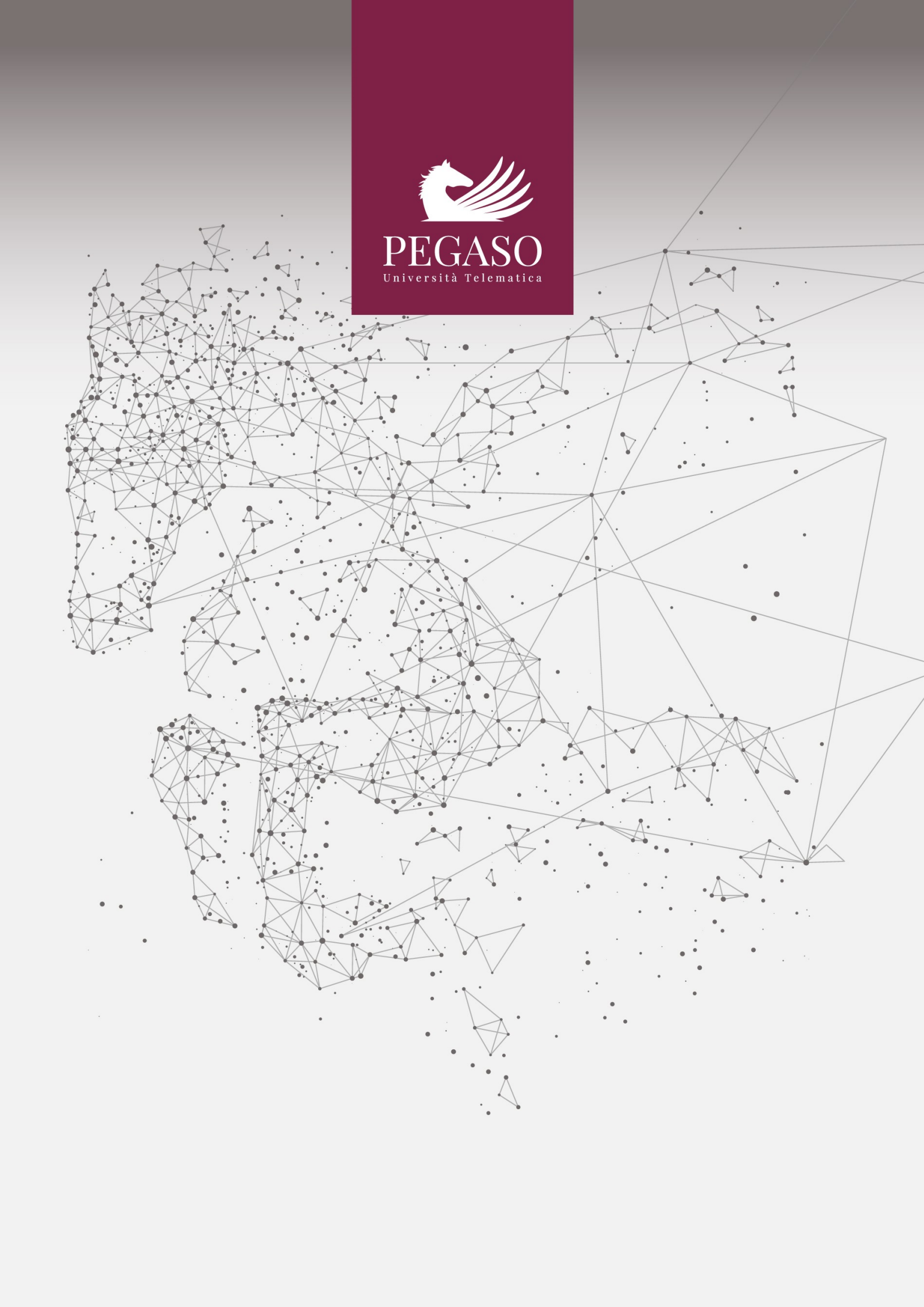

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1. INTRODUZIONE A X.509 3
2. FORMATO CERTIFICATO X.509 5
3. GESTIONE CERTIFICATI X.509 7
BIBLIOGRAFIA 11

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1. Introduzione a X.509

X.509 è una raccomandazione del ITU-T che fa parte della serie di raccomandazioni X.500 che definiscono un «servizio di directory». Con il termine «servizio di directory» si intende *uno o più server che gestiscono un database di informazioni sugli utenti*. X.509 definisce sostanzialmente un framework per fornire servizi di autenticazione tramite la directory X.500 basato sull'uso di certificati. X.509 prevede inoltre l'uso della crittografia a chiave pubblica (consigliata RSA) e l'impiego di funzioni di hash (non esiste in questo caso nessuna indicazione specifica).

Ogni certificato contiene la chiave pubblica del possessore del certificato ed è firmato con la chiave privata dell'autorità fidata di certificazione che ha emesso tale certificato. X.509 rappresenta sicuramente uno standard molto importante in quanto impiegato in vari contesti quali S/MIME, IPSec, SSL/TLS e SET.

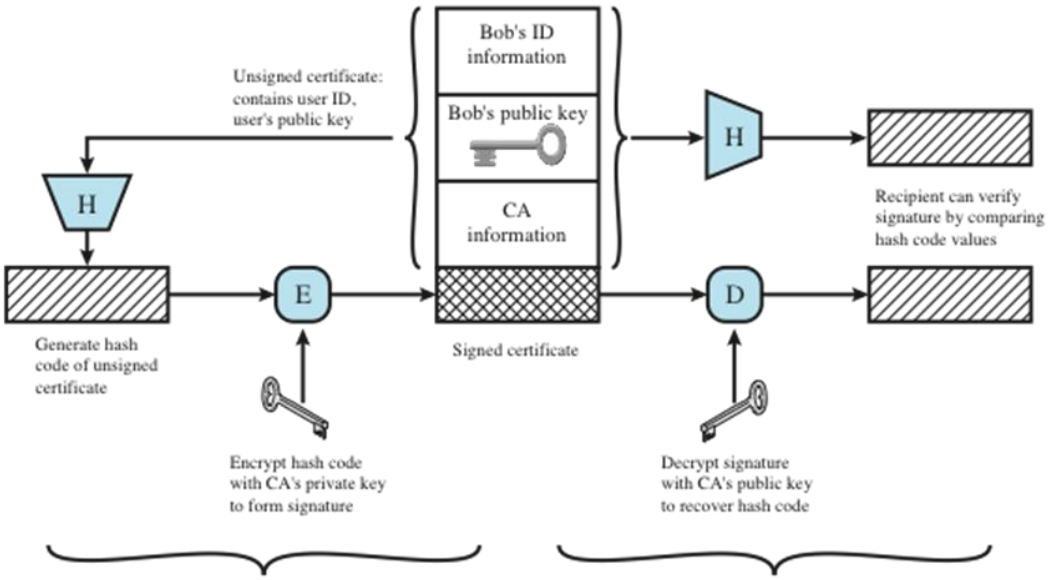
X.509 è stato emesso in una prima versione nel 1988 per poi subire un aggiornamento nel 1993 ed arrivare alla versione 3 (v3) a sua volta rivista nel 2000.

Il certificato a chiave pubblica rappresenta il cuore del meccanismo X.509; i certificati vengono creati da un'autorità di certificazione ed inseriti nella directory da tale autorità o dall'utente stesso. Esempi di Autorità di Certificazione sono: *Verisign, Comodo* e *Actalis* (Italia)

La generazione di un certificato a chiave pubblica avviene come rappresentato nella figura seguente:

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).



Creazione del certificato di Bob firmato dalla CA

Uso del certificato di Bob per verificare la sua chiave pubblica

Il certificato non ancora firmato contiene le informazioni dell'utente, la sua chiave pubblica e le informazioni sulla autorità di certificazione (Certification Authority - CA); di questi dati viene effettuato un hash che viene firmato con la chiave privata della CA. Tale firma viene concatenata con la parte del certificato non firmato.

L'utente destinatario che riceve il certificato può verificarne l'autenticità effettuando l'hash della parte non firmata del certificato e confrontando quanto ottenuto con quanto estratto dalla firma usando per decifrarla la chiave pubblica della CA. Se il risultato coincide il certificato è valido.

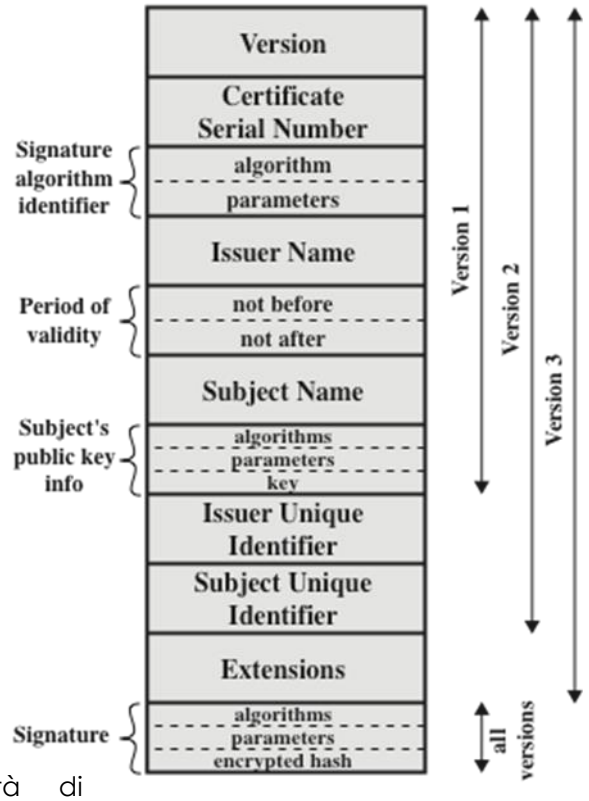
PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2. Formato certificato X.509

Il certificato X.509 ha uno specifico formato che prevede determinati campi (vedi figura):

- *Versione*: distingue la versione 1 predefinita da quella che contiene gli identificatori univoci dell'emettitore e del soggetto (v2) da quella che contiene le estensioni (v3)
- *Numero seriale del certificato*: numero univoco del certificato assegnato dall'autorità di certificazione
- *Identificatore algoritmo di firma*: algoritmo usato per firmare il certificato (scarsa utilità in quanto c'è nel campo firma).



- *Nome dell'emettitore*: il nome dell'autorità di certificazione che ha emesso il certificato
- *Periodo di validità*: data di inizio e fine validità
- *Nome del soggetto*: il nome dell'utente titolare del certificato

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

- *Informazioni sulla chiave pubblica del soggetto*: contiene la chiave pubblica del soggetto, identificatore dell'algoritmo e altri parametri
- *Identificatori univoci* (opzionali): servono nel caso in cui lo stesso nome venga usato da più entità
- *Estensioni:* previste per la versione 3.
- *Firma*: contiene l'hash degli altri campi crittografato con la chiave privata dell'autorità di certificazione e informazioni sull'algoritmo

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3. Gestione certificati X.509

I certificati X.509 hanno le seguenti caratteristiche:

- ogni utente con accesso alla chiave pubblica dell'autorità di certificazione può verificare la chiave pubblica dell'utente contenuta nel certificato
- nessuno, ad eccezione dell'autorità di certificazione, può modificare il certificato senza essere rilevato
- poiché i certificati non sono modificabili possono essere messi in una directory senza nessuna necessità di protezione
- un utente può anche trasmettere direttamente il suo certificato ad altri utenti

I certificati X.509 sono rilasciati da autorità di certificazione diverse

- Se l'utente A non riesce a procurarsi in maniera sicura la chiave pubblica della CA_B che ha rilasciato il certificato di B, allora non potrà verificarne la firma
- Se invece le due CA (CA_A per l'utente A e CA_B per l'utente B) si sono scambiate tra di loro i certificati allora l'utente A può prendere il certificato della CA_B firmato dalla sua autorità di certificazione CA_A (di cui conosce la chiave pubblica in modo sicuro) ed ottenere la chiave pubblica di CA_B
- Può adesso verificare il certificato dell'utente B e ottenere con sicurezza la chiave pubblica di B
- *I certificati delle CA sono organizzati in gerarchie*

I certificati possono anche essere *revocati*:

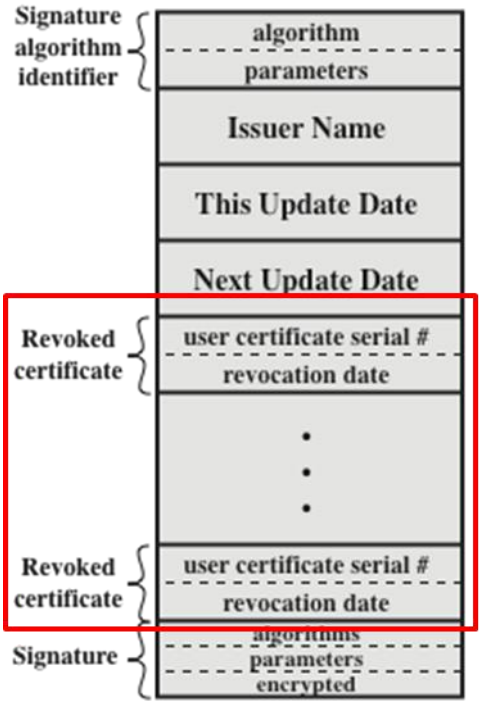
- esiste un periodo di validità: poco prima della scadenza ne viene emesso un altro valido
- talvolta il certificato viene revocato prima della scadenza:
    - la chiave privata è stata violata
    - l'utente non è più certificato da quella CA

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

- il certificato della CA è stato violato

- Ogni autorità di certificazione deve gestire e pubblicare una lista di certificati revocati (*CRL-Certificate Revocation List*) ma non scaduti.



La lista di revoca (vedi figura qui sopra), inviata nella directory, è firmata dall'entità emettitore (e.g. l'autorità stessa) e contiene:

- *l'identificatore dell'algoritmo di firma*
- *il nome dell'emettitore*
- *la data di creazione della lista*
- *la data del prossimo aggiornamento*
- *un campo per ogni certificato revocato composto da numero seriale e data di revoca* (vedi box in rosso in figura)
- *firma della lista di revoca*

La versione 2 di X.509 non forniva tutte le informazioni che si sono poi dimostrate necessarie nell'esperienza. Invece di aggiungere campi ad un formato fisso, gli sviluppatori dello standard

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

hanno deciso di realizzare una **versione 3** che includesse varie estensioni opzionali da essere aggiunte alla versione 2.

Ogni estensione è costituita da:

- un identificatore
- un indicatore di importanza (l'estensione può essere ignorata o no)

Tali estensioni riguardano tre categorie:

- *Informazioni sulla chiave e la politica*: indicano per esempio se un certificato è applicabile in un certo contesto o per una certa classe di applicazioni
- *Attributi del soggetto e dell'emettitore del certificato*: supportano nomi alternativi sia per il soggetto che per l'emettitore, forniscono informazioni aggiuntive (e.g. indirizzo postale)
- *Vincoli nel percorso di certificazione*: specificano dei vincoli da includere nei certificati di autorità di certificazione emessi da altre autorità di certificazione

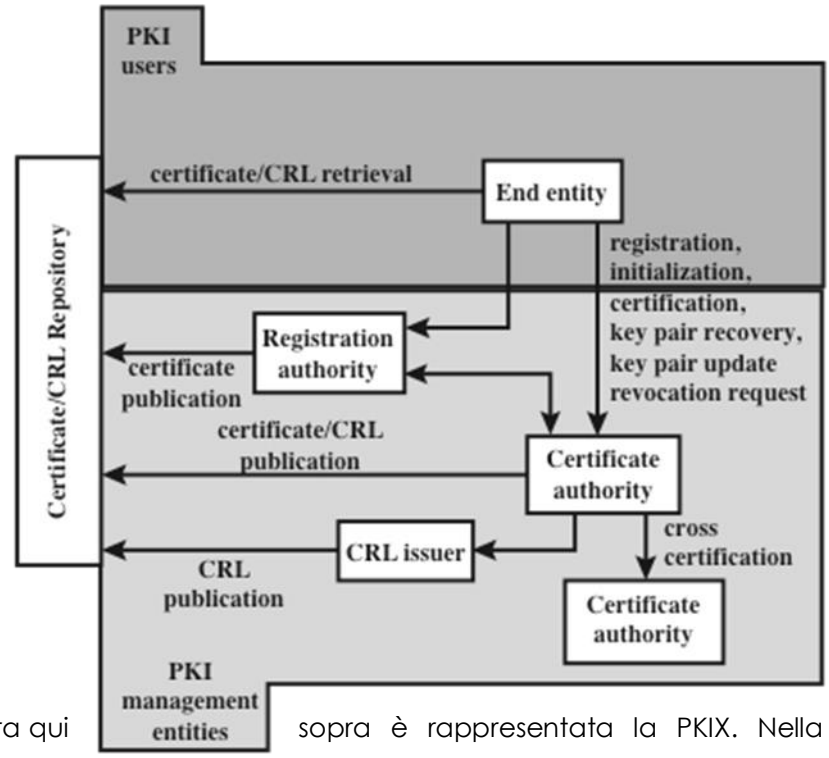
Lo standard **PKIX (*Public Key Infrastructure X.509*)** definisce un modello formale basato su X.509 per la messa in opera su Internet di un'architettura basata sui certificati. Esso definisce le entità in gioco e le varie funzioni di gestione (registrazione, recupero del certificato, pubblicazione liste di revoca, ecc.)

Le entità in gioco sono:

- L'*utente finale*
- L'*autorità di certificazione*: emette i certificati (anche le liste di revoca)
- L'*autorità di registrazione* (opzionale): supporta la CA per la registrazione degli utenti
- L'*emittente delle liste di revoca (opzionale)*: si occupa di pubblicare le liste di revoca
- *Repository dei certificati e delle liste di revoca*

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).



Nella figura qui sopra è rappresentata la PKIX. Nella parte in alto è evidenziata la parte relativa agi utenti che possono recuperare il loro certificato e/o la CRL; nella parte inferiore invece sono illustrate le entità che nella PKI si occupano della gestione, come l'autorità di certificazione (CA) che ovviamente possono essere più di una, eventualmente l'autorità di registrazione che può essere diversa dalla CA e infine l'emettitore della CRL che può essere anche un soggetto diverso rispetto alla CA stessa.

PEGASO Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia

- Libro di riferimento "Crittografia e Sicurezza delle Reti" 2 ed., William Stallings, Ed. McGraw-Hill: Capitoli 14.
- "Cryptography and Network Security", 7/ed, William Stallings, Pearson.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).